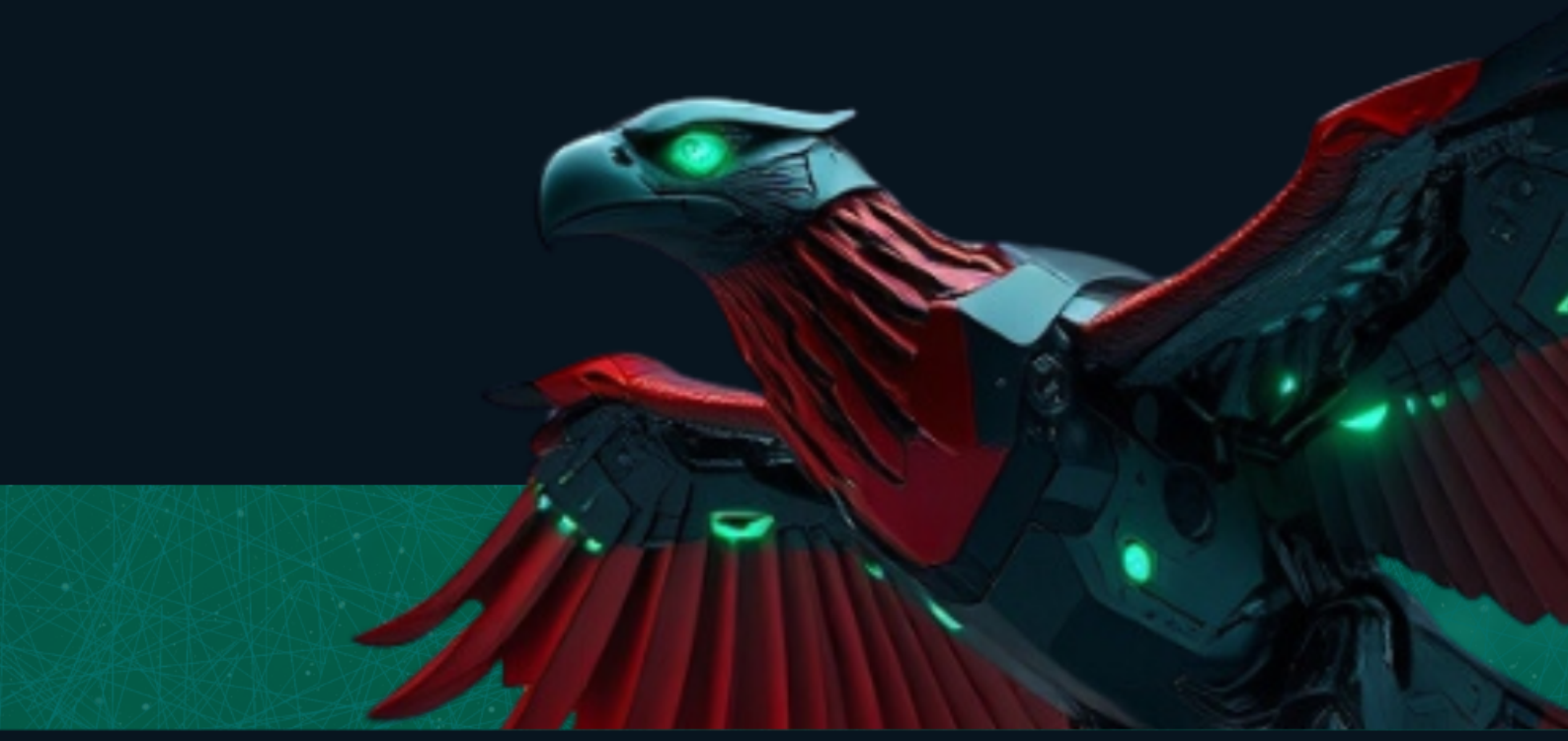
SOCBYTE
ALL BYTES SECURED

INTEL REPORT



Report Details

Title	Dead.Letter
Sub Title	Exim BDAT Vulnerability Can Lead To Code Execution
Status	Closed
Type	Advisory
Severity	—
Source	TheHackerNews.com
Created At	May 13, 2026, 01:38 PM

Dead.Letter

Exim BDAT Vulnerability Can Lead To Code Execution

Type: ADVISORY • Source: TheHackerNews.com • Created At: May 13, 2026, 01:38 PM

Analysis Summary

A critical vulnerability, tracked as CVE-2026-45185 and nicknamed "Dead.Letter," has been discovered in the Exim mail transfer agent. It has been assigned a CVSS Base Score of 9.8 (Critical). This flaw is a use-after-free vulnerability that specifically affects Exim builds using GnuTLS for encryption. The issue arises during the handling of binary data transmission (BDAT) message bodies. If a client sends a TLS "close_notify" alert before a body transfer is finished and follows it with a final byte in cleartext, Exim may attempt to write to a memory buffer that has already been freed, leading to heap corruption.

The vulnerability is considered high-risk because it can lead to unauthenticated remote code execution (RCE) and an ASLR bypass, allowing an attacker to potentially take full control of an affected email server. It impacts Exim versions 4.97 through 4.99.2, but only those configured with USE_GNUTKS=yes. Systems relying on other libraries, such as OpenSSL, are not susceptible to this specific bug.

The technical root cause involves a race condition in memory management during a TLS session teardown. If a remote client sends a TLS close_notify alert before a BDAT body transfer is complete, and then immediately follows it with a final byte in cleartext on the same TCP connection, a nested BDAT receive wrapper may attempt to process the incoming byte. During this process, Exim calls the ungetc() function, which writes a single newline character (\n) into a memory buffer that was just freed by the TLS shutdown. This "one-byte write" targets the allocator's metadata, leading to heap corruption.Exploitation of this vulnerability can result in unauthenticated remote code execution (RCE) and has been demonstrated to bypass Address Space Layout Randomization (ASLR). Because the attack requires only the ability to establish a TLS connection and use the CHUNKING (BDAT) SMTP extension, requiring no special server configuration, it is considered high-risk.

Affected Product

- Exim mail transfer agents running versions 4.97 through 4.99.2 compiled with GnuTLS utilizing Chunking (BDAT) extension

Impact

- Remote Code Execution
- ASLR Bypass
- Full Server Takeover
- Compromised Communication
- Network Pivot Point
- Internal Phishing
- Minimal Configuration Barriers

Vulnerabilities (CVEs)

CVE Number	Description	Published	CVSS Score
CVE-2026-45185	A critical Use-After-Free (UAF) vulnerability in Exim mail servers (before 4.99.3) using GnuTLS, allowing for remote code execution (RCE).	5/11/2026	9.8

Remediation

To mitigate and respond to the CVE-2026-45185 vulnerability, organizations must immediately upgrade to Exim version 4.99.3, which implements a clean reset of the input processing stack to prevent the use of stale pointers during TLS shutdowns. Because the flaw is a fundamental memory corruption issue triggered by standard SMTP and TLS signaling, there are no known functional workarounds or configuration-based mitigations that can resolve the underlying risk. Beyond patching, response teams should conduct a retroactive analysis of Exim paniclog and rejectlog for "Unexpected bytes after TLS shutdown" errors and monitor network traffic for the specific Dead.Letter signature, a TLS close_notify followed by cleartext bytes—to identify potential exploitation attempts. In the event that a compromise is suspected, the affected mail server should be isolated to prevent lateral movement, and a full forensic audit should be performed to check for unauthorized shells or persistence mechanisms.